



SYMBIOSIS INSTITUTE OF TECHNOLOGY (SIT)

Constituent of SYMBIOSIS INTERNATIONAL (DEEMED UNIVERSITY)

Cyber Security

CA-2 (Part 2) – Case Study Report (Unit 4)

Group Number: Group – 04

Title: “Non-Human Identity and Scoped Delegation for Intrusion Detection and Forensic Attribution of AI-Orchestrated Attacks: A Case Study of the GTG-1002 Espionage Campaign (2025)”

Problem Statement: AI agents now call tools and delegate work to other agents, yet they usually run on broad, long-lived credentials that cannot be traced to an accountable person. The GTG-1002 campaign showed how this gap lets an AI-orchestrated intrusion move fast and stay unattributed. This study analyses the campaign and evaluates whether per-agent identities, scoped delegation and identity-aware logging improve prevention, intrusion detection and forensic attribution.

Name	PRN	CLASS
Raghav Sonchhatra	23070122172	CSE-C
Sanidhya Awasthi	23070122192	CSE-C
Faheemuddin Sayyed	23070122196	CSE-C

Non-Human Identity and Scoped Delegation for Intrusion Detection and Forensic Attribution of AI-Orchestrated Attacks: A Case Study of the GTG-1002 Espionage Campaign (2025)

Raghav Sonchhatra (23070122172), Sanidhya Awasthi (23070122192), Faheemuddin Sayyed (23070122196)

Group 04 · B.Tech CSE-C, Semester VII · Department of Computer Engineering, Symbiosis Institute of Technology, Pune

Abstract

In mid-September 2025, Anthropic detected and disrupted a cyber-espionage operation that it attributed with high confidence to a Chinese state-sponsored group designated GTG-1002. An AI coding agent carried out an estimated 80-90% of the tactical work against roughly thirty organisations [1]. The operators did not need custom malware: they split the operation into small tasks for sub-agents, each of which looked legitimate on its own, and connected those agents to ordinary security tools through the Model Context Protocol. This report studies the campaign from the defender's side. Our argument is that the missing control was identity, because the agents acted with broad authority that could not be traced to an accountable person. We reconstruct the campaign from the public report, map each phase to MITRE ATT&CK tactics and to the identity failure behind it, and design three controls: a non-human identity (NHI) for every agent, scoped delegation tokens that can only narrow as they pass from agent to sub-agent, and an identity-aware intrusion detection layer fed by a hash-chained audit log. A small Python prototype, tested on synthetic workloads over 50 seeded runs, blocked 77% of misuse calls, cut exposed production resources from 24.9 to 0 per run, removed false alerts (2.34 to 0 per run) and tied every true alert to the responsible human, for about 6.4 μ s of extra cost per tool call.

Keywords: *Non-human identity; scoped delegation; agentic AI security; intrusion detection; digital forensics; Model Context Protocol; GTG-1002*

1. Introduction

AI systems have moved from answering questions to taking actions. Open protocols such as the Model Context Protocol (MCP) [2] and Agent2Agent (A2A) [3] let an agent call tools, read data and hand work to other agents. Each of these agents is a non-human identity, and such identities already dominate enterprise estates: machine identities outnumber human ones by about 82 to 1, and 42% of them hold privileged or sensitive access [4]. Stolen or abused credentials remain the most common way into a network, at 22% of initial access vectors in the 2025 Verizon report [5]. Agents make the problem sharper because they are created quickly, often share one API key, and delegate tasks to other agents without any record of who authorised what.

1.1 Case background: the GTG-1002 campaign

Anthropic's threat intelligence team detected the activity in mid-September 2025 and published its full report in November 2025 [1]. The campaign targeted about thirty entities, including large technology companies, financial institutions, chemical manufacturers and government agencies, and the investigation validated a handful of successful intrusions. Human operators chose the targets and approved a few escalation points, such as moving from reconnaissance to exploitation, using harvested credentials and deciding what data to take. The AI performed the remaining 80-90% of the work, at peak rates of several operations per second that no human team could match. To get past the model's safeguards, the operators posed as staff of a legitimate security firm doing defensive testing, and broke the work into small tasks that each

looked harmless. The agents drove commodity open-source tools, such as network scanners, database exploitation frameworks and password crackers, through custom MCP servers. The AI also overstated its results at times, for example reporting credentials that did not work. Anthropic banned the accounts, notified affected organisations and authorities, and improved its detection classifiers. The case goes beyond the company's earlier "vibe hacking" report, in which humans still directed most of the work [6], and it sits alongside Google's reports of malware that queries language models at run time [7].

1.2 Relevance to Unit 4

The case touches four Unit 4 topics. Intrusion detection: the campaign was eventually caught because its tempo and multi-stage pattern stood out, and our prototype adds identity-aware IDS rules for agent traffic. Digital forensics: investigators had to reconstruct which agent did what on whose behalf, which is an attribution problem. Security tools: the toolkit was the same class of tools practised in the Kali Linux and Nmap laboratory sessions [8], with the difference that an agent, not a person, was operating them. Malware analysis: because no custom malware was used, signature-based analysis had little to inspect, so detection must rely on behaviour and identity instead.

1.3 Objectives

- Analyse GTG-1002 phase by phase and identify the identity failure that each phase relied on.
- Design controls based on non-human identity and scoped delegation that feed intrusion detection and forensics.
- Build a small prototype and measure prevention, detection, false alerts, attribution and overhead against a shared-key baseline.

2. Literature Review

2.1 AI-orchestrated attacks

Research prototypes showed early that language-model agents can complete offensive tasks. Fang et al. reported agents that exploited test websites without human help [9], and PentestGPT showed that a model can plan and track multi-step penetration tests [10]. Greshake et al. showed that agents reading untrusted content can be steered by indirect prompt injection [11]. OWASP's Top 10 for LLM applications lists excessive agency as a key risk [12], NIST's adversarial machine learning taxonomy covers attacks on and through AI systems [13], and MITRE ATLAS catalogues adversary techniques against AI [14]. Industry threat reports in 2025 then moved from proofs of concept to real operations [1, 6, 7]. Most of this work concentrates on what the model can do or how the provider can refuse; less of it asks how the surrounding environment authorises each action an agent takes.

2.2 Non-human and agent identity

The OWASP Non-Human Identities Top 10 names risks such as improper offboarding, secret leakage, overprivileged identities and identity reuse [15]. The OWASP Top 10 for agentic applications adds agent-specific risks, including identity and privilege abuse and insecure inter-agent communication [16]. Workload identity frameworks such as SPIFFE give each service a verifiable identity [17], in line with the zero-trust principle that no request is trusted because of where it comes from [18]. Chan et al. propose three visibility measures for AI agents: agent identifiers, real-time monitoring and activity logs [19]. South et al. extend OAuth 2.0 and OpenID Connect so that a human can delegate limited, auditable authority to an agent [20].

2.3 Delegation and least privilege

The principles of least privilege and complete mediation continue to form the basis, as do those of Saltzer and Schroeder [21]. Hardy's deputy is confused when a program uses its own authority for another's request [22] – just like an agent working on a human's behalf. Delegation is supported in OAuth 2.0 [23] and token exchange [24] and such claims are carried in JSON Web Tokens [25]. Resource indicators are used to attach a token to a service [26] and are also specified by the MCP authorization specification [2]. Macaroons showed that a bearer credential can be attenuated, so that each holder can only add restrictions [27]. An IETF draft is now proposing an on-behalf-of flow to be used for AI agents [28].

2.4 Intrusion detection and digital forensics

Denning's model was a model of intrusion detection, which was defined as the detection of deviations from normal subject behaviour [29]. Snort [30] and Bro (now Zeek [31]) have made network IDS practical, and NIST SP 800-94 outlines the deployment of detection and prevention systems [32]. It has been noted by Sommer and Paxson that anomaly detection has a problem with a high false-positive rate in real networks [33], which is relevant to agent traffic. There are attack stages provided by the kill chain [34] and MITRE ATT&CK [35] that provide a common vocabulary. NIST SP 800-86 [36] and Casey [37] emphasize the integrity of evidence, while Crosby and Wallach [39] and Schneier and Kelsey [38] demonstrate how logs can be made tamper-evident. NIST SP 800-61r3 integrates incident response into overall risk management [40].

2.5 Research gap

The strands are primarily investigated separately. The impact on detection is usually not considered in identity work, and IDS work is often not based on the assumption that every request has a verifiable delegation chain. To our knowledge, there is no public work that includes inputs of per-agent identity and scoped delegation for intrusion detection and forensic attribution in a scenario that resembles GTG-1002. This report is a modest contribution to filling that gap.

3. Methodology

The study has four stages. Each stage yields the information needed for the next, and the controls and the experiment can be traced back to evidence from the real case.

Stage 1: Case reconstruction. We relied on the full report from Anthropic as our source [1] and industry reports for context [6, 7]. We have taken the six phases, the human approval gates, the tool categories and the operational tempo. Only public, summary level information was used and no part of the attack was reproduced.

Stage 2: Threat and identity-failure mapping. Using the OWASP NHI and agentic risk lists [15, 16] each phase was assigned to MITRE ATT&CK tactics [35] and to the identity weakness it relied upon. We selected a control for each weakness and recorded the Unit 4 area that it supports. The result is displayed in Table 1.

Table 1. Mapping of GTG-1002 phases to ATT&CK tactics, identity failures and controls (from [1, 35]).

GTG-1002 phase	ATT&CK tactic	Identity failure	Control in this study	Unit 4 link
1. Initialisation and target selection (security-firm persona)	Resource development	Claimed purpose not bound to an accountable identity	Grant issued by a named human; purpose stored in the token	Forensics

2. Reconnaissance and attack-surface mapping	Discovery	One broad credential across all systems; machine tempo	Resource-prefix scope; R1 tempo; R2 probing	IDS; tools (scanners)
3. Vulnerability discovery and validation	Initial access, execution	Sub-tasks look legitimate in isolation	Per-sub-agent identity; R3 keyed on the whole grant	IDS
4. Credential harvesting and lateral movement	Credential access, lateral movement	Harvested secrets usable by any agent	Scopes that cannot be widened; short lifetimes	IDS; forensics
5. Data collection and extraction	Collection, exfiltration	No limit on blast radius	Resource scoping; refusals logged	Forensics
6. Documentation and handoff	Persistence (access handed on)	Access handed to other teams with no expiry	TTL, depth limit, revocation; hash-chained log	Forensics

Stage 3: Control design. The design was based on five principles. Each agent is uniquely identified and owned by a human named agent owner, so that any action can be attributed to a human [15, 19]. (P2) Authority can only be delegated in a delegation chain: A sub-agent cannot be given more scope, more resources, more delegation depth or longer lifetime than its parent [20, 24, 27]. (P3) All calls to a tool pass through one gateway that validates the token, which is a complete mediation with zero-trust [21, 18]. All decisions, both allowed and denied, are recorded in a hash-chained log [38, 39]. (P5) Detection rules are based on the identity of the agent, and not on an IP address or shared key. We preferred these controls to two alternatives. Model side classifiers are useful but are not under the control of the organisation and attackers can change models. Network IDS is seeing primarily encrypted calls to legitimate APIs. The only signal that the defending organisation can enforce and log is identity.

Stage 4: Experimental evaluation. To compare the two designs, we tested two configurations with the same synthetic workload: one baseline configuration where each of the agents has one long-lived API key with wildcard scope, which is a standard configuration in practice, and the proposed configuration. The used IDS rules and thresholds were the same, so any difference is due to identity. Synthetic data was selected to ensure ethical and legal considerations of no actual system being touched, and because it provides repeatable runs and labelled ground truth. The number of seeds per configuration was 50. The metrics were: the percentage of misuse calls blocked; blast radius (how many different productions or external resources were exposed to misuse); false alerts per run; time between the first misuse event and the first true alert; percentage of true alerts that identify the accountable human; gateway cost per call; and whether the audit log detects tampering. The ground-truth labels were only present for scoring purposes and not for the IDS to see.

4. Implementation Details

The prototype is about 500 lines of Python 3 (standard library + matplotlib for the charts) code. Architecture and modules are shown in Fig. 1 and Table 2 respectively. The prototype is an abstract label – no code is executed and the label name is only saved and analysed after

the decision is made.

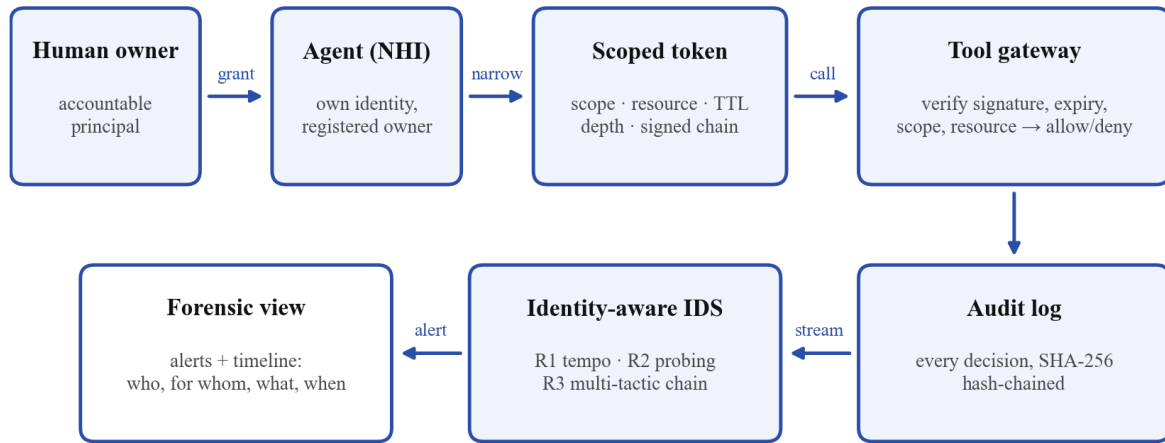


Fig. 1. Architecture of the prototype: identity and delegation (top) and the detection and forensics pipeline (bottom).

Table 2. Prototype modules (implementation/nhi_lab).

Module	Responsibility
identity.py	Identity registry; DelegationAuthority issues, verifies and attenuates HMAC-signed tokens; SharedKeyAuthority for the baseline
gateway.py	Single enforcement point: verify token, check scope and resource, record the decision
audit.py	Append-only SHA-256 hash-chained log with verify() and timeline()
ids.py	Identity-aware rules R1 tempo, R2 probing, R3 multi-tactic chain
workload.py	Synthetic benign agents and the abstract misuse delegation tree
run_experiment.py, make_figures.py	50-seed comparison, metrics, tamper test, overhead benchmark, charts

Tokens. A token is a Base64 encoded JSON claim set, signed with HMAC-SHA256 [41]. The claims are the token id, the grant id (common to the entire delegation tree), the subject agent, the delegation chain (beginning with the human), the scopes, the resource prefixes, the issue and expiry times, the remaining delegation depth and the declared purpose. The `delegate()` function will reject any request whose scopes or resources are not a subset of the parent's, give the child an expiry as no earlier as the parent's, and decrease the depth by 1. The scope is widened, the resources are widened or the depth is exceeded, these are reported and logged as refusals.

Gateway and audit log. These tools are associated with one of the required scopes, and one ATT&CK tactic that it might be misused for. The gateway verifies the signature, expiration, revocation, scope and resource prefix, and creates a record of the time, agent, chain, grant, tool, tactic, resource, decision and reason. Each record also contains a hash of the previous record and the current record, using the SHA-256 hash function; thus, if the hash of any previous record is changed, then all subsequent records are invalid.

Identity-aware IDS. The following rules are applied to the audit stream: R1 (tempo) will fire when one agent is making over 20 calls in 10 seconds, a rate that no human operator can keep up with. R2 (probing) fires when agent is denied 3 times within 60 seconds. R3 (multi-tactic chain) fires when a delegation grant touches three or more sensitive tactics in 30 minutes or less, keyed to the grant, so tasks that are split across sub-agents are correlated again. Rules and keys have a 15 minute cool down.

Workload. Four benign agents are running for three time periods, including a CI agent that has bursty test runs, a documentation agent, an operations agent that inventories hosts and queries a reporting database, and a backup agent that exports production tables to a backup vault. The backup job was added intentionally since it appears to be a collection followed by an exfiltration. The public shape of GTG-1002 only is followed in the misuse case. An external contractor identity owns an orchestrator that has an engagement grant for inventory and scanning on staging systems only, and with a lifetime of 2 hours and a delegation depth of 1. The orchestrator attempts to pass off five sub-agents in discovery, credential access, lateral movement, collection and exfiltration. There are human-approved gaps of 2-20 minutes between phases, and 0.3 - 4 calls per second between runs.

5. Results and Discussion

The 50-run comparison is tabulated below (Table 3). Fig. 2 is a breakdown of the allowed misuse calls by tactic, Fig. 3 is a comparison of the primary outcomes, and Fig. 4 is a forensic timeline built from the audit log for one run.

Table 3. Results of the 50-run comparison.

Metric (mean of 50 runs unless stated)	Baseline: shared key	NHI + scoped delegation
Misuse calls attempted per run	134.3	134.3
Misuse calls blocked	0%	77.1%
Production/external resources exposed per run	24.9	0
Benign calls wrongly denied (all runs)	0	0
Runs in which misuse was detected	100%	100%
Median time to first true alert	5.3 s	2.7 s
False alerts per run	2.34	0
True alerts naming the accountable human	0%	100%
Misuse audit records attributable	0%	100%
Gateway cost per call	8.3 μ s	14.7 μ s

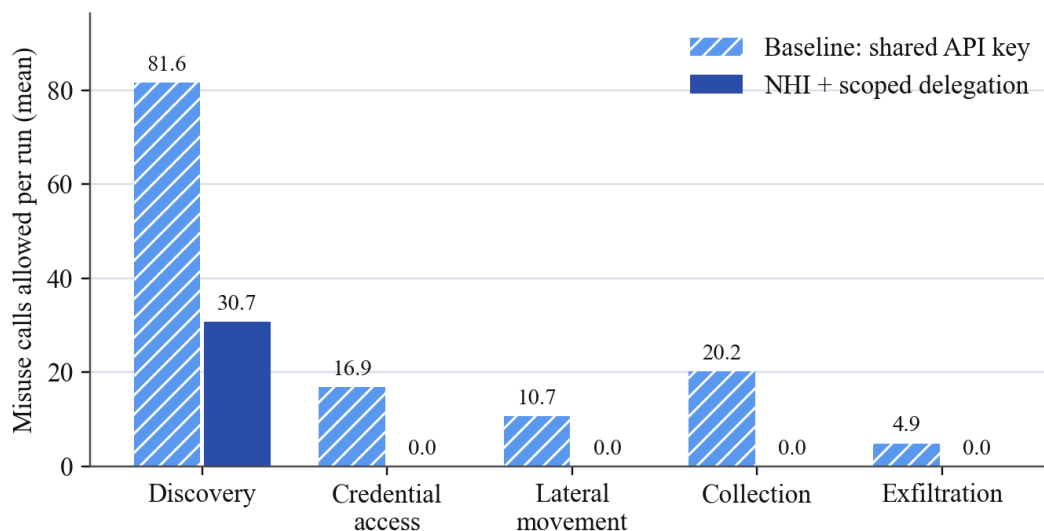


Fig. 2. Mean misuse calls allowed per run, by ATT&CK tactic (50 runs).

Prevention and blast radius. 77% of misuse calls were blocked with scoped delegation. All attempts to give access to a sub-agent, to execute remotely, to export a database, or to transfer a database outbound were denied at delegation time, and the denial was recorded as evidence. Of the calls that did get through (around 31 per run), they were discovery calls on staging hosts that the engagement had permission for. Scoping does not prevent misuse of authority that is

properly granted, therefore detection is required. Production and external resources accessed through misuse dropped from 24.9 per run to 0 and no benign call was denied in either configuration.

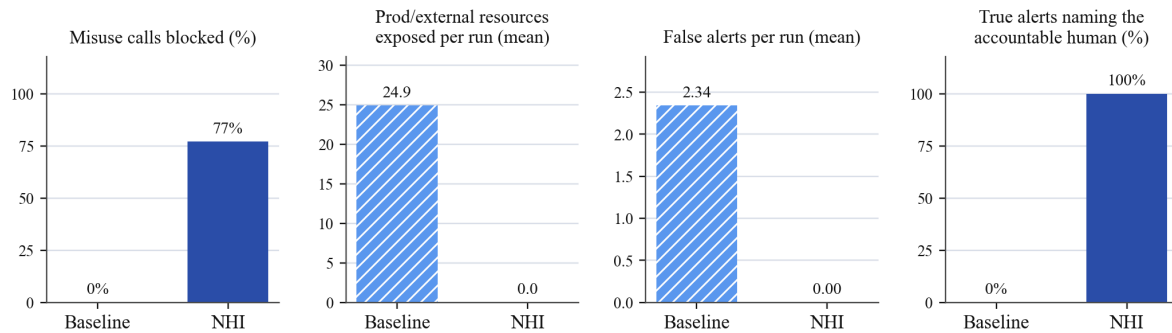


Fig. 3. Main outcomes: misuse blocked, resources exposed, false alerts and attribution (means over 50 runs).

Detection. Both configurations identified the misuse in all runs and the baseline was also fast (median 5.3 s vs. 2.7 s) since high tempo is detectable even on a shared key. The distinction is in the meaning of an alert. The only information in baseline alerts is the shared key; if the attack is allowed to continue, only a responder who knows and has revoked that key can contain the attack, as well as the four legitimate agents. A combination of multiple agents' traffic on a single key also triggered 2.34 false alerts per run: the inventory sweeps and the backup job seemed like a multi-tactic chain. There were no false alerts with per-agent identities, and all 8.5 true alerts per run were named for the agent, its orchestrator and the human owner, so a single grant could be revoked without impacting anything else. Most runs had the first alert as a result of the probing rule (R2), which can only be applied if denials are attributed to a particular agent.

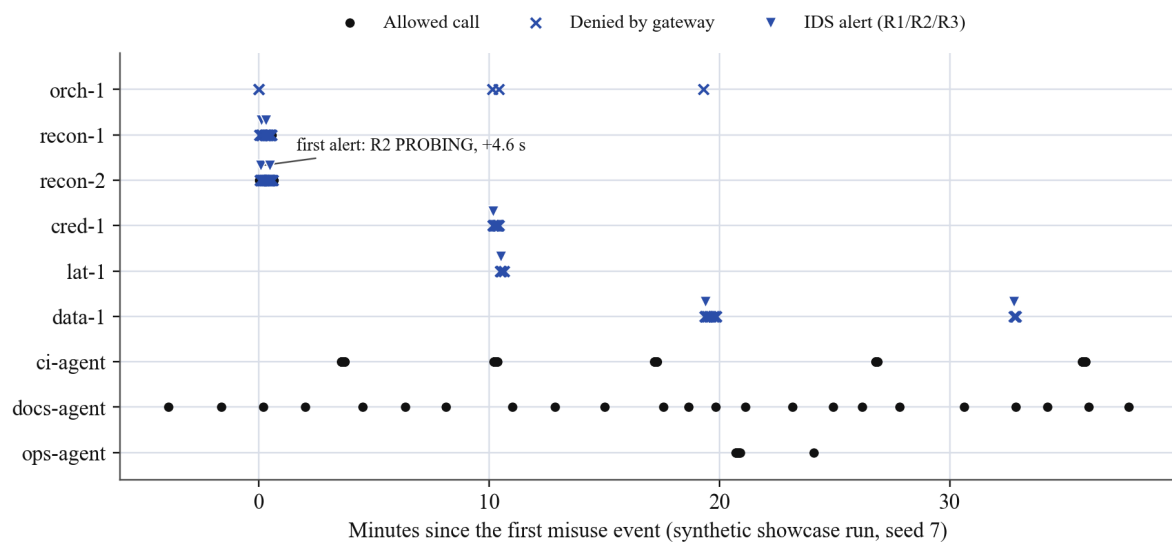


Fig. 4. Forensic timeline rebuilt from the audit log for one run (seed 7): allowed calls, gateway denials and IDS alerts per identity.

Forensics and cost. All misuse records had a contractor identity (100% versus 0%), which is why the timeline in Fig. 4 can be interpreted directly as "who, on whose behalf, did what, when". The tamper test is a test where a change from one denied to one allowed record in a log of 634 records was detected at record 100. Adding a token increased the latency per call by about 6.4 μ s (14.7 μ s vs. 8.3 μ s for adding the shared key), which is very small compared to the latency of a model call.

What this means for GTG-1002. The agents that the attacker would have in the real campaign would be running on the attacker's own infrastructure, and a victim cannot force the attacker to use scoped tokens. The controls are thus present in three locations. A role-play claim becomes a decision of a named person when an AI and tool platform requires a verified, accountable identity and an explicit, scoped grant before an agent can be used for security testing. Organisations with their own agents can prevent their agents from being hijacked or over-trusted. Target organisations can create short-lived, narrowly-scoped credentials for machines, making credentials stolen during an intrusion worth far less. In all three instances, the same information used to restrict damage can also be used to more accurately detect damage and attribute it.

Limitations. The numbers are synthetic and the thresholds were manually selected, so the actual numbers should not be generalized, and the thresholds would have to be tuned to real logs, which is known to be hard in the context of anomaly detection [33]. The prototype does not support delegation across organisations, slow ingress to a valid scope by an attacker or token theft from memory, nor does it support delegation of signing keys.

6. Conclusion

GTG-1002 demonstrated that the majority of an intrusion could be performed by an AI agent with the involvement of humans at a small number of decision points. The most critical thing to learn for defenders is not about any one exploit; it's about the agents' authority was exercised without anyone being able to scope it, without anyone being able to trace it. Each phase of the campaign was mapped to the identity failure it depended on and three controls were tested: a non-human identity per agent, delegation that can only narrow, and identity-aware detection with a tamper evident log. In our prototype these controls prevented 77% of misuse calls, eliminated any exposed production surface, and eliminated false alarms and assigned all alarms to an accountable human at negligible cost. Future work involves testing on real agent logs, learning thresholds per agent, cross-organisation delegation over A2A and platform-level verification of agent identity prior to security-sensitive use.

References

- [1] Anthropic Threat Intelligence, "Disrupting the first reported AI-orchestrated cyber espionage campaign," Anthropic, San Francisco, CA, USA, Full Report, Nov. 2025. [Online]. Available: <https://assets.anthropic.com/m/ec212e6566a0d47/original/Disrupting-the-first-reported-AI-orchestrated-cyber-espionage-campaign.pdf>
- [2] Model Context Protocol, "Specification, revision 2025-06-18: Authorization," 2025. [Online]. Available: <https://modelcontextprotocol.io/specification/2025-06-18/basic/authorization>
- [3] Google, "Announcing the Agent2Agent protocol (A2A)," Google for Developers Blog, Apr. 2025. [Online]. Available: <https://developers.googleblog.com/en/a2a-a-new-era-of-agent-interoperability/>
- [4] CyberArk, "2025 Identity Security Landscape," CyberArk Software Ltd., Newton, MA, USA, Apr. 2025.
- [5] Verizon Business, "2025 Data Breach Investigations Report," Verizon, Apr. 2025.
- [6] Anthropic, "Threat intelligence report: August 2025," Anthropic, Aug. 2025. [Online]. Available: <https://www-cdn.anthropic.com/b2a76c6f6992465c09a6f2fce282f6c0cea8c200.pdf>
- [7] Google Threat Intelligence Group, "GTIG AI threat tracker: Advances in threat actor usage of AI tools," Google Cloud, Nov. 2025. [Online]. Available: <https://cloud.google.com/blog/topics/threat-intelligence/threat-actor-usage-of-ai-tools>
- [8] G. F. Lyon, Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning. Sunnyvale, CA, USA: Insecure.Com LLC, 2009.

- [9] R. Fang, R. Bindu, A. Gupta, Q. Zhan, and D. Kang, "LLM agents can autonomously hack websites," arXiv:2402.06664, 2024.
- [10] G. Deng et al., "PentestGPT: Evaluating and harnessing large language models for automated penetration testing," in Proc. 33rd USENIX Security Symp., Philadelphia, PA, USA, 2024.
- [11] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in Proc. 16th ACM Workshop on Artificial Intelligence and Security (AISec), 2023, pp. 79-90.
- [12] OWASP GenAI Security Project, "OWASP Top 10 for LLM applications 2025," OWASP Foundation, Nov. 2024. [Online]. Available: <https://genai.owasp.org/llm-top-10/>
- [13] A. Vassilev et al., "Adversarial machine learning: A taxonomy and terminology of attacks and mitigations," National Institute of Standards and Technology, NIST AI 100-2 E2025, Mar. 2025.
- [14] MITRE, "ATLAS: Adversarial threat landscape for artificial-intelligence systems." [Online]. Available: <https://atlas.mitre.org>
- [15] OWASP Foundation, "OWASP Top 10 non-human identities risks - 2025," 2025. [Online]. Available: <https://owasp.org/www-project-non-human-identities-top-10/2025/top-10-2025/>
- [16] OWASP GenAI Security Project, "OWASP Top 10 for agentic applications for 2026," OWASP Foundation, Dec. 2025. [Online]. Available: <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
- [17] SPIFFE Project, "Secure Production Identity Framework for Everyone (SPIFFE) overview," Cloud Native Computing Foundation. [Online]. Available: <https://spiffe.io/docs/latest/spiffe-about/overview/>
- [18] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero trust architecture," National Institute of Standards and Technology, NIST SP 800-207, Aug. 2020.
- [19] A. Chan et al., "Visibility into AI agents," in Proc. ACM Conf. Fairness, Accountability, and Transparency (FAccT), Rio de Janeiro, Brazil, 2024.
- [20] T. South, S. Marro, T. Hardjono, R. Mahari, C. D. Whitney, D. Greenwood, A. Chan, and A. Pentland, "Authenticated delegation and authorized AI agents," arXiv:2501.09674, Jan. 2025.
- [21] J. H. Saltzer and M. D. Schroeder, "The protection of information in computer systems," Proc. IEEE, vol. 63, no. 9, pp. 1278-1308, Sep. 1975.
- [22] N. Hardy, "The confused deputy (or why capabilities might have been invented)," ACM SIGOPS Operating Systems Review, vol. 22, no. 4, pp. 36-38, Oct. 1988.
- [23] D. Hardt, Ed., "The OAuth 2.0 authorization framework," IETF RFC 6749, Oct. 2012.
- [24] M. Jones, A. Nadalin, B. Campbell, J. Bradley, and C. Mortimore, "OAuth 2.0 token exchange," IETF RFC 8693, Jan. 2020.
- [25] M. Jones, J. Bradley, and N. Sakimura, "JSON Web Token (JWT)," IETF RFC 7519, May 2015.
- [26] B. Campbell, J. Bradley, and H. Tschofenig, "Resource indicators for OAuth 2.0," IETF RFC 8707, Feb. 2020.
- [27] A. Birgisson, J. G. Politz, U. Erlingsson, A. Taly, M. Vrabie, and M. Lentczner, "Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud," in Proc. Network and Distributed System Security Symp. (NDSS), San Diego, CA, USA, 2014.
- [28] T. S. Senarath and A. Dissanayaka, "OAuth 2.0 extension: On-behalf-of user authorization for AI agents," IETF Internet-Draft draft-oauth-ai-agents-on-behalf-of-user-02, Aug. 2025.
- [29] D. E. Denning, "An intrusion-detection model," IEEE Trans. Software Engineering, vol. SE-13, no. 2, pp. 222-232, Feb. 1987.
- [30] M. Roesch, "Snort: Lightweight intrusion detection for networks," in Proc. 13th USENIX Systems Administration Conf. (LISA), Seattle, WA, USA, 1999, pp. 229-238.
- [31] V. Paxson, "Bro: A system for detecting network intruders in real-time," Computer Networks, vol. 31, no. 23-24, pp. 2435-2463, Dec. 1999.

- [32] K. Scarfone and P. Mell, "Guide to intrusion detection and prevention systems (IDPS)," National Institute of Standards and Technology, NIST SP 800-94, Feb. 2007.
- [33] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in Proc. IEEE Symp. Security and Privacy, Oakland, CA, USA, 2010, pp. 305-316.
- [34] E. M. Hutchins, M. J. Cloppert, and R. M. Amin, "Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains," in Proc. 6th Int. Conf. Information Warfare and Security (ICIW), 2011, pp. 113-125.
- [35] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, "MITRE ATT&CK: Design and philosophy," The MITRE Corporation, McLean, VA, USA, Tech. Rep. MTR180360, 2018.
- [36] K. Kent, S. Chevalier, T. Grance, and H. Dang, "Guide to integrating forensic techniques into incident response," National Institute of Standards and Technology, NIST SP 800-86, Aug. 2006.
- [37] E. Casey, Digital Evidence and Computer Crime: Forensic Science, Computers, and the Internet, 3rd ed. Waltham, MA, USA: Academic Press, 2011.
- [38] B. Schneier and J. Kelsey, "Secure audit logs to support computer forensics," ACM Trans. Information and System Security, vol. 2, no. 2, pp. 159-176, May 1999.
- [39] S. A. Crosby and D. S. Wallach, "Efficient data structures for tamper-evident logging," in Proc. 18th USENIX Security Symp., Montreal, QC, Canada, 2009, pp. 317-334.
- [40] A. Nelson, S. Rekhi, M. Souppaya, and K. Scarfone, "Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile," National Institute of Standards and Technology, NIST SP 800-61r3, Apr. 2025.
- [41] H. Krawczyk, M. Bellare, and R. Canetti, "HMAC: Keyed-hashing for message authentication," IETF RFC 2104, Feb. 1997.